

Badania bezpieczeństwa systemu

Wstęp i opis stanowiska badawczego

Celem niniejszego rozdziału jest przeprowadzenie testów bezpieczeństwa zaprojektowanego i wdrożonego systemu automatyki domowej, opartego na mikrokontrolerach ESP oraz protokole MQTT. Ze względu na specyfikę urządzeń Internetu Rzeczy (IoT), które często posiadają ograniczone zasoby obliczeniowe i mogą być podatne na różnego rodzaju ataki sieciowe, kluczowym elementem ochrony systemu jest zapewnienie odpowiedniej izolacji sieciowej na poziomie warstwy 3 (sieciowej) oraz kontrola dostępu w wyższych warstwach modelu OSI/ISO.

W celu zasymulowania rzeczywistych warunków pracy systemu oraz potencjalnych zagrożeń, przygotowano dedykowane stanowisko badawcze. Głównym założeniem projektowym było odseparowanie urządzeń IoT od głównej sieci domowej użytkownika, w której mogą znajdować się wrażliwe urządzenia (np. komputery osobiste, serwery NAS). Do realizacji tego zadania wykorzystano dwuinterfejsowy (dual-homed) serwer oparty na systemie Debian oraz router TP-Link, który tworzy osobną podsieć dla urządzeń automatyki domowej.

Stanowisko badawcze składa się z następujących komponentów:

1. Dwuinterfejsowy serwer Debian:

- Pełni rolę centralnej jednostki zarządzającej automatyką domową (broker MQTT, serwer aplikacji).
- Wyposażony jest w dwie karty sieciowe:
 - Interfejs bezprzewodowy (Wi-Fi) o adresie IP 192.168.8.100, podłączony do sieci IoT.
 - Interfejs przewodowy (Ethernet) o adresie IP 192.168.1.17, podłączony do sieci domowej/ISP.

2. Router IoT (TP-Link):

- Tworzy odseparowaną sieć bezprzewodową dla urządzeń automatyki domowej.
- Adres IP interfejsu LAN routera to 192.168.8.1 (podsieć 192.168.8.0/24).
- Port WAN routera jest podłączony do portu LAN routera dostawcy usług internetowych (ISP). Adres IP interfejsu WAN jest przydzielany dynamicznie (DHCP) z puli sieci nadrzędnej 192.168.1.0/24 (w warunkach testowych router otrzymał adres 192.168.1.32).

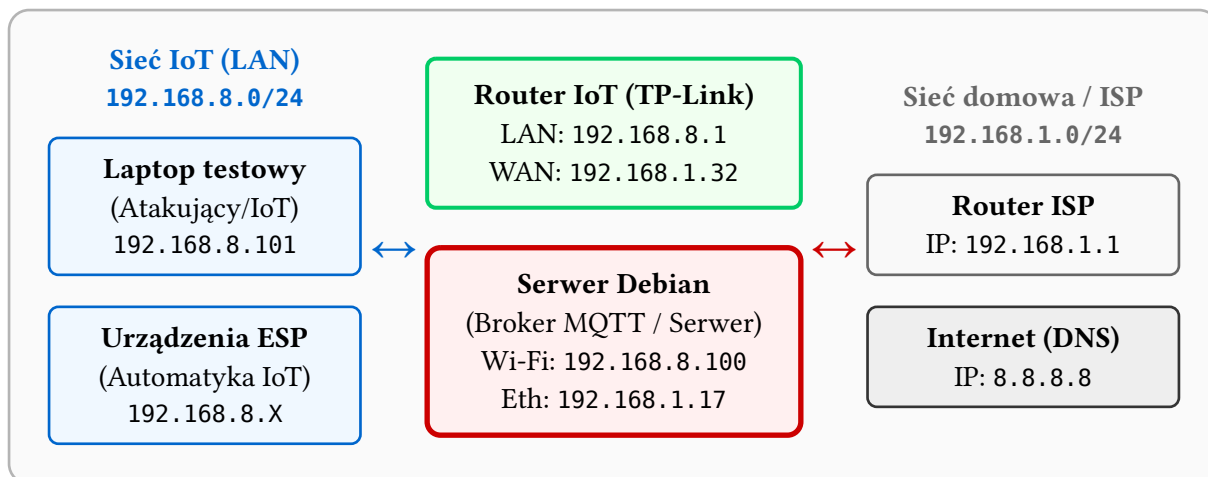
3. Laptop testowy (system Linux):

- Działa w podsieci IoT pod adresem IP 192.168.8.101.
- W badaniach symuluje zainfekowane lub nieautoryzowane urządzenie IoT próbujące uzyskać dostęp do innych segmentów sieci.

4. Router ISP i Internet:

- Reprezentują sieć domową nadrzędną (192.168.1.0/24) oraz sieć globalną.
- Adres bramy domyślnej w sieci ISP to 192.168.1.1. Jako cel testów dostępności usług zewnętrznych wykorzystano publiczny serwer DNS Google o adresie IP 8.8.8.8.

Topologię logiczną przygotowanego stanowiska badawczego przedstawiono na Listing 1.



Listing 1: Topologia sieciowa stanowiska badawczego

W dalszej części rozdziału przedstawiono szczegółową analizę przeprowadzonych testów bezpieczeństwa podzielonych na testy w warstwie sieciowej (Layer 3) oraz testy w warstwie aplikacji (Layer 4).

Testy w warstwie sieciowej (Layer 3) - Izolacja sieciowa

Niniejsza sekcja opisuje eksperymenty przeprowadzone w celu zbadania mechanizmów separacji ruchu w warstwie sieciowej. Testy polegały na weryfikacji drożności pakietów ICMP Echo (polecenie ping) pomiędzy różnymi węzłami sieciowymi w trzech różnych scenariuszach konfiguracji fizycznej i logicznej routerów.

Scenariusz 1: Brak połączenia fizycznego routera TP-Link z siecią domową (ISP)

W pierwszym scenariuszu badawczym przetestowano zachowanie sieci w sytuacji pełnej izolacji fizycznej. Router TP-Link (obsługujący sieć IoT) nie został połączony swoim portem WAN z siecią domową/ISP. Oznacza to, że podsieć bezprzewodowa 192.168.8.0/24 funkcjonowała jako sieć całkowicie lokalna i zamknięta (offline).

Celem testu było sprawdzenie możliwości komunikacji laptopa testowego (192.168.8.101) z interfejsem bezprzewodowym serwera (192.168.8.100), jego interfejsem przewodowym (192.168.1.17) należącym do sieci nadrzędnej, oraz z hostem w sieci Internet (8.8.8.8). Wyniki testu przedstawiono na zrzucie ekranu (Figure 1).

```

angelo@angelo-ThinkPad-T470-W10DG:~$ ip a | grep w
3: wlp4s0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 192.168.8.101/24 brd 192.168.8.255 scope global dynamic noprefixroute wlp4s0
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.8.100
PING 192.168.8.100 (192.168.8.100) 56(84) bytes of data.
64 bytes from 192.168.8.100: icmp_seq=1 ttl=64 time=104 ms
64 bytes from 192.168.8.100: icmp_seq=2 ttl=64 time=25.8 ms
64 bytes from 192.168.8.100: icmp_seq=3 ttl=64 time=48.5 ms
64 bytes from 192.168.8.100: icmp_seq=4 ttl=64 time=71.8 ms

--- 192.168.8.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3001ms
rtt min/avg/max/mdev = 25.762/62.477/103.852/28.910 ms
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.1.17
PING 192.168.1.17 (192.168.1.17) 56(84) bytes of data.
From 192.168.8.1 icmp_seq=4 Destination Net Unreachable

--- 192.168.1.17 ping statistics ---
4 packets transmitted, 0 received, +1 errors, 100% packet loss, time 3001ms

angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
From 192.168.8.1 icmp_seq=1 Destination Net Unreachable
From 192.168.8.1 icmp_seq=2 Destination Net Unreachable
From 192.168.8.1 icmp_seq=3 Destination Net Unreachable
From 192.168.8.1 icmp_seq=4 Destination Net Unreachable

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3006ms

angelo@angelo-ThinkPad-T470-W10DG:~$

```

Figure 1: Wyniki testów ping dla Scenariusza 1

Analiza wyników i wnioski

- Komunikacja lokalna (Wi-Fi):** Próba połączenia z adresem 192.168.8.100 zakończyła się pełnym sukcesem (0% utraconych pakietów, średni czas RTT wyniósł ok. 75,9 ms). Wynika to z faktu, że oba urządzenia znajdują się w tej samej sieci fizycznej i logicznej (warstwa 2 i 3). Ruch sieciowy odbywa się wewnątrz punktu dostępowego routera TP-Link i nie wymaga zaangażowania mechanizmów routingu.
- Komunikacja z siecią nadrzędną (Ethernet):** Próba wysłania pakietów ICMP Echo Request do adresu 192.168.1.17 (karta przewodowa serwera) zakończyła się niepowodzeniem (100% strat pakietów). Laptop testowy wysyła pakiety do swojej bramy domyślnej (192.168.8.1), jednak ze względu na brak połączenia fizycznego portu WAN routera TP-Link z siecią nadrzędną oraz brak wpisu w tablicy routingu dla sieci 192.168.1.0/24, pakiety te nie mogą zostać dostarczone.
- Komunikacja z siecią Internet:** Próba pingowania adresu 8.8.8.8 również zakończyła się niepowodzeniem. Router TP-Link (192.168.8.1) odesłał komunikaty ICMP Destination Net Unreachable (Host docelowy jest nieosiągalny). Wynika to z braku aktywnego połączenia WAN (brak adresu IP WAN oraz bramy domyślnej po stronie WAN routera TP-Link), co uniemożliwia wyznaczenie trasy do sieci zewnętrznych.

Podsumowując, Scenariusz 1 wykazuje pełną, szczelną izolację sieci IoT od sieci domowej oraz od sieci Internet. Choć taka konfiguracja charakteryzuje się najwyższym poziomem bezpieczeństwa (uniemożliwia ataki z zewnątrz oraz wyciek danych), to jest niepraktyczna w wielu zastosowaniach automatyki domowej. Uniemożliwia ona zdalne sterowanie systemem spoza lokalnej sieci Wi-Fi, korzystanie z zewnętrznych usług chmurowych, integrację z asystentami głosowymi czy synchronizację czasu urządzeń ESP przez protokół NTP.

Scenariusz 2: Połączenie routerów (WAN-LAN) bez reguł kontroli dostępu

W drugim scenariuszu badawczym router TP-Link został fizycznie połączony portem WAN z portem LAN routera dostawcy (ISP). Konfiguracja ta odzwierciedla powszechnie stosowany schemat kaskadowego łączenia routerów (tzw. podwójny NAT), gdzie sieć IoT (192.168.8.0/24) znajduje się

za routerem TP-Link, a główna sieć domowa/ISP (192.168.1.0/24) stanowi sieć nadrzędną. W tym scenariuszu na routerze TP-Link nie skonfigurowano żadnych dodatkowych reguł zapory sieciowej ani kontroli dostępu (Access Control). Stan funkcji kontroli dostępu na routerze przedstawiono na Figure 2.

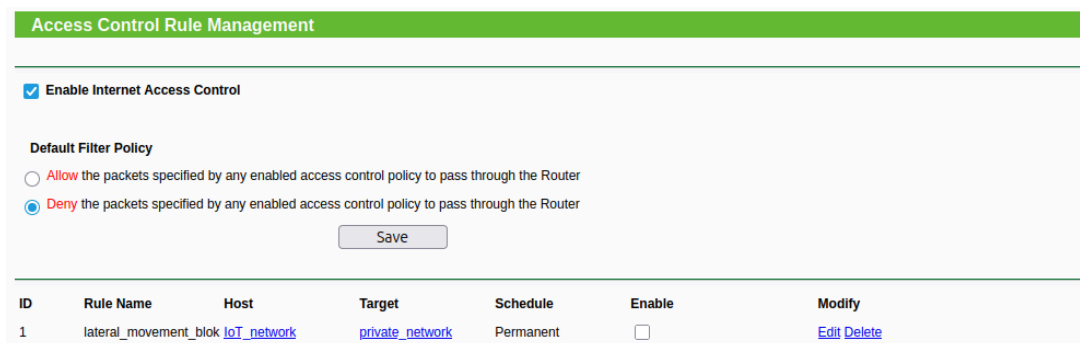


Figure 2: Interfejs zarządzania routerem TP-Link z wyłączoną funkcją kontroli dostępu

Celem testu było sprawdzenie, czy domyślne mechanizmy routingu i NAT na routerze TP-Link zapewniają izolację sieci domowej przed dostępem z sieci IoT. Wyniki prób pingowania z laptopa testowego (192.168.8.101) do wybranych celów przedstawiono na Figure 3.

```
angelo@angelo-ThinkPad-T470-W10DG:~$ ip a | grep w
3: wlp4s0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 192.168.8.101/24 brd 192.168.8.255 scope global dynamic noprefixroute wlp4s0
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.8.100
PING 192.168.8.100 (192.168.8.100) 56(84) bytes of data.
64 bytes from 192.168.8.100: icmp_seq=1 ttl=64 time=216 ms
64 bytes from 192.168.8.100: icmp_seq=2 ttl=64 time=39.2 ms
64 bytes from 192.168.8.100: icmp_seq=3 ttl=64 time=61.3 ms
64 bytes from 192.168.8.100: icmp_seq=4 ttl=64 time=85.0 ms

--- 192.168.8.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 39.207/100.338/215.839/68.624 ms
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.1.17
PING 192.168.1.17 (192.168.1.17) 56(84) bytes of data.
64 bytes from 192.168.1.17: icmp_seq=1 ttl=63 time=15.3 ms
64 bytes from 192.168.1.17: icmp_seq=2 ttl=63 time=5.76 ms
64 bytes from 192.168.1.17: icmp_seq=3 ttl=63 time=3.78 ms
64 bytes from 192.168.1.17: icmp_seq=4 ttl=63 time=3.78 ms

--- 192.168.1.17 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 3.778/7.146/15.265/4.756 ms
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=117 time=20.8 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=117 time=10.3 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=117 time=10.4 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=117 time=9.99 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 9.993/12.859/20.776/4.572 ms
angelo@angelo-ThinkPad-T470-W10DG:~$
```

Figure 3: Wyniki testów ping dla Scenariusza 2

Analiza wyników i wnioski

- Komunikacja lokalna (Wi-Fi):** Ping do adresu 192.168.8.100 przebiegł pomyślnie. Zmiana fizycznej konfiguracji routera (podłączenie portu WAN) nie wpłynęła na komunikację wewnątrz lokalnego przełącznika i punktu dostępowego Wi-Fi routera TP-Link.
- Komunikacja z siecią nadrzędną (Ethernet):** Próba pingowania interfejsu przewodowego serwera (192.168.1.17) zakończyła się **sukcesem** (0% strat pakietów). Czas odpowiedzi (RTT ok. 3,8 ms) był bardzo niski ze względu na bezpośrednie połączenie kablowe routerów. Wartość pola

TTL w pakietach zwrotnych wyniosła 63. Ponieważ domyślna wartość TTL dla systemów operacyjnych Linux wynosi 64, zmniejszenie jej o 1 oznacza, że pakiet przeszedł przez dokładnie jedno urządzenie pośredniczące (router TP-Link).

3. **Komunikacja z siecią Internet:** Ping do adresu 8.8.8.8 również zakończył się sukcesem. Urządzenie z sieci IoT bez przeszkód komunikowało się z zewnętrznym internetem przez kaskadę routerów (TP-Link oraz router ISP).

Wykazanie luki bezpieczeństwa

Wyniki tego testu dowodzą obecności poważnej luki w zabezpieczeniach domyślnej konfiguracji sieci kaskadowej. Powszechne przekonanie, że umieszczenie urządzeń IoT za osobnym routerem chroni domową sieć LAN, jest błędne.

- **Jednokierunkowa ochrona (Ingress):** Mechanizm NAT (Network Address Translation) realizowany przez router TP-Link chroni sieć IoT przed bezpośrednim dostępem inicjowanym z sieci nadrzędnej (192.168.1.0/24). Urządzenia z sieci domowej nie mogą bezpośrednio nawiązać połączenia z mikrokontrolerami ESP (chyba że zostaną skonfigurowane reguły przekierowania portów).
- **Brak izolacji ruchu wychodzącego (Egress):** Router TP-Link traktuje podsieć 192.168.1.0/24 (sieć domową/ISP) jako część interfejsu WAN, czyli jako sieć zewnętrzną. W związku z tym domyślnie zezwala na trasowanie i translację (NAT) każdego ruchu wychodzącego z sieci IoT do sieci domowej.

Konfiguracja ta stwarza wysokie ryzyko dla bezpieczeństwa. Jeśli napastnik przejmie kontrolę nad podatnym mikrokontrolerem ESP (np. poprzez lukę w oprogramowaniu lub atak na protokół komunikacyjny), może on potraktować to urządzenie jako punkt wyjścia (pivot) do dalszej eksploracji i ataków na urządzenia w sieci domowej (192.168.1.0/24), takie jak komputery osobiste, serwery NAS czy systemy monitoringu wizyjnego.

Scenariusz 3: Połączenie routerów (WAN-LAN) z włączonymi regułami kontroli dostępu

Trzeci scenariusz badawczy stanowi rozwinięcie scenariusza drugiego. Układ fizyczny połączeń pozostał bez zmian (port WAN routera TP-Link połączony z portem LAN routera ISP). Wprowadzono jednak kluczową modyfikację w konfiguracji logicznej routera TP-Link – aktywowano funkcję kontroli dostępu (Access Control). Stan wdrożenia reguły zaprezentowano na Figure 4.

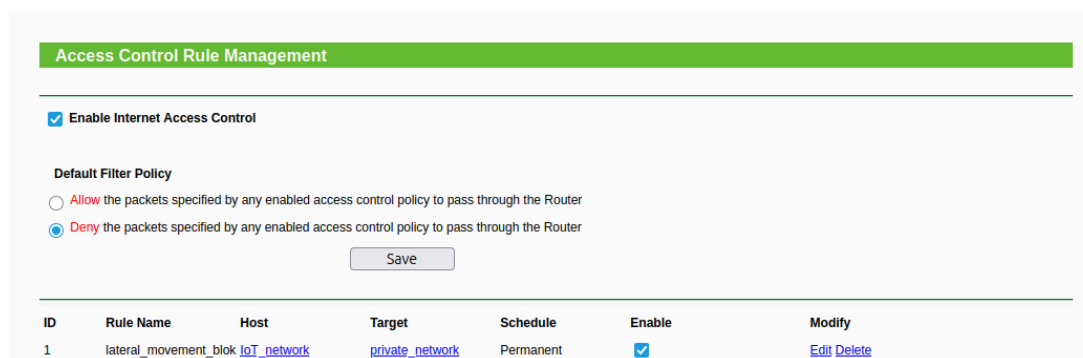


Figure 4: Interfejs zarządzania routera TP-Link z aktywną regułą blokowania ruchu do sieci domowej

Reguła ta została zaimplementowana w następujący sposób:

- **Źródło (Source):** Wszystkie hosty z sieci bezprzewodowej IoT (192.168.8.0/24).

- **Cel (Destination):** Zakres adresów IP odpowiadający sieci nadrzędnej/domowej (192.168.1.0/24).
- **Działanie (Action):** Zablokowanie (Deny/Block) każdego rodzaju ruchu.
- **Ruch pozostały:** Zezwolenie na ruch kierowany do pozostałych adresów IP (np. sieci Internet).

Wyniki testów komunikacyjnych przeprowadzonych z laptopa testowego (192.168.8.101) przedstawiono na zrzucie ekranu (Figure 5).

```
angelo@angelo-ThinkPad-T470-W10DG:~$ ip a | grep w
3: wlp4s0: <BROADCAST,MULTICAST,UP,LOWER UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 192.168.8.101/24 brd 192.168.8.255 scope global dynamic noprefixroute wlp4s0
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.8.100
PING 192.168.8.100 (192.168.8.100) 56(84) bytes of data.
64 bytes from 192.168.8.100: icmp_seq=1 ttl=64 time=46.5 ms
64 bytes from 192.168.8.100: icmp_seq=2 ttl=64 time=70.4 ms
64 bytes from 192.168.8.100: icmp_seq=3 ttl=64 time=93.1 ms
64 bytes from 192.168.8.100: icmp_seq=4 ttl=64 time=215 ms

--- 192.168.8.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 46.524/106.214/214.867/64.854 ms
angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 192.168.1.17
PING 192.168.1.17 (192.168.1.17) 56(84) bytes of data.

--- 192.168.1.17 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3089ms

angelo@angelo-ThinkPad-T470-W10DG:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=117 time=10.5 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=117 time=15.7 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=117 time=12.0 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=117 time=9.63 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 9.627/11.952/15.681/2.316 ms
angelo@angelo-ThinkPad-T470-W10DG:~$
```

Figure 5: Wyniki testów ping dla Scenariusza 3

Analiza wyników i wnioski

1. **Komunikacja lokalna (Wi-Fi):** Ping do adresu 192.168.8.100 zakończył się sukcesem. Wynika to z faktu, że reguła kontroli dostępu na TP-Link dotyczy wyłącznie interfejsu WAN. Komunikacja wewnątrz sieci LAN/WLAN nie jest filtrowana przez reguły zapory sieciowej routera. Umożliwia to mikrokontrolerom ESP bezproblemową i bezpośrednią komunikację z serwerem Debian (brokerem MQTT) na interfejsie bezprzewodowym.
2. **Komunikacja z siecią nadrzędną (Ethernet):** Próba pingowania adresu 192.168.1.17 (interfejs przewodowy serwera) zakończyła się całkowitym niepowodzeniem (100% strat pakietów). Router TP-Link, po odebraniu pakietu zaadresowanego do sieci 192.168.1.0/24, dopasował go do zdefiniowanej reguły blokującej i odrzucił go przed wysłaniem na interfejs WAN. Cel izolacji został osiągnięty.
3. **Komunikacja z siecią Internet:** Ping do adresu 8.8.8.8 przebiegł pomyślnie. Ponieważ cel ten nie pasował do zdefiniowanej reguły blokującej (sieć 192.168.1.0/24), ruch został przetłumaczony (NAT) i przesłany dalej do bramy ISP, a stamtąd do internetu.

Wnioski dotyczące bezpieczeństwa

Konfiguracja przetestowana w Scenariuszu 3 stanowi rekomendowaną metodę wdrażania bezpiecznych systemów automatyki domowej w środowisku domowym. Zapewnia ona optymalną równowagę między bezpieczeństwem a funkcjonalnością:

- **Skuteczna izolacja:** Ewentualne przejęcie kontroli przez napastnika nad dowolnym urządzeniem IoT (np. mikrokontrolerem ESP) nie daje mu możliwości skanowania, komunikacji ani atakowania urządzeń znajdujących się w głównej domowej sieci LAN.
- **Funkcjonalność lokalna i zdalna:** Urządzenia IoT mogą komunikować się z lokalnym brokerem MQTT na adresie 192.168.8.100, a jednocześnie zachowują dostęp do internetu, co umożliwia im np. synchronizację czasu (NTP), pobieranie aktualizacji oprogramowania (OTA) czy komunikację z chmurami zewnętrznymi (np. Home Assistant Cloud, Blynk).

Warto zauważyć, że w tej konfiguracji serwer Debian pełni rolę tzw. “bastionu” (dual-homed bastion host). Z racji podłączenia do obu podsieci stanowi on krytyczny punkt architektury bezpieczeństwa. Jeśli serwer Debian zostanie skompromitowany, napastnik uzyska dostęp do obu sieci. W związku z tym zabezpieczenie samego serwera (np. poprzez reguły firewall ufw na serwerze, wyłączenie niepotrzebnych usług, silne uwierzytelnianie) musi być traktowane priorytetowo.

Testy w warstwie aplikacji (Layer 4) - Bezpieczeństwo protokołu MQTT

Sekcja w przygotowaniu:

W tym podrozdziale opublikowane zostaną wyniki testów w warstwie transportowej i aplikacji (Layer 4), koncentrujące się na analizie bezpieczeństwa komunikacji MQTT (np. brak szyfrowania TLS, podatność na podsłuchiwanie wiadomości, ataki typu replay oraz testy autoryzacji tematów MQTT).